Cybersecurity Risk Assessment Framework for Small Businesses

Naviotech Solution Pvt Ltd — Cyber Security Internship Minor Project 1 Submitted by:
Ayush Singh

1. Introduction

Small and medium enterprises (SMEs) are increasingly targeted by cyberattacks, yet most lack the dedicated security teams and budgets that larger organizations rely on. This project develops a practical, repeatable model for evaluating cybersecurity risks in SMEs and proposes mitigation strategies to improve their security posture.

1.1 Objectives

- Research the cybersecurity risks most commonly faced by SMEs
- Build a risk assessment model grounded in the NIST Cybersecurity Framework
- Create a quantitative risk evaluation metric to rank threats by severity and impact
- Propose practical, low-cost mitigation strategies suited to SME budgets
- Validate the model against a representative case study

2. Common Cybersecurity Risks in SMEs

Research into SME security incidents consistently points to a small set of recurring risks:

Risk	Description
Phishing	Deceptive emails or messages designed to steal credentials or deliver malware
Ransomware	Malicious software that encrypts data and demands payment for its release
Insider threats	Accidental or malicious harm caused by employees or contractors with legitimate access
Weak or reused passwords	Credentials that are easily guessed, reused across services, or never rotated

Risk	Description
Unpatched software	Known vulnerabilities left unfixed due to delayed updates
Misconfigured cloud storage	Publicly exposed files or databases due to incorrect access settings
Lack of employee awareness	Staff untrained in recognizing social engineering or safe data handling

SMEs are frequently targeted precisely because attackers expect weaker defenses and smaller security budgets than large enterprises, making them a comparatively easier target for the same payoff.

3. Risk Assessment Model

This framework is built on the **NIST Cybersecurity Framework (CSF)**, which organizes security activity into five core functions:

Function	Purpose	Applied to SMEs
Identify	Understand assets, data, and risks	Inventory devices, data, and third-party services
Protect	Implement safeguards	Firewalls, MFA, access control, backups
Detect	Identify security events	Monitoring tools, log review, anomaly alerts
Respond	Act on detected incidents	Incident response plan, communication steps
Recover	Restore normal operations	Backup restoration, post-incident review

Each risk identified in Section 2 is mapped against these five functions to determine where the SME's current gaps lie, and which function most urgently needs investment.

4. Risk Evaluation Metric

Each risk is scored on two independent 1–5 scales, then combined into a single priority score:

- **Likelihood** (1 = rare, 5 = almost certain): how probable the risk is, given typical SME practices
- **Impact** (1 = minor, 5 = severe): the potential damage to data, finances, or reputation
- **Risk Score = Likelihood × Impact** (maximum 25)

Risk	Likelihood	Impact	Risk Score	Priority
Phishing	5	4	20	Critical
Ransomware	3	5	15	High
Weak/reused passwords	4	3	12	High
Unpatched software	3	4	12	High
Insider threats	2	4	8	Medium
Misconfigured cloud storage	2	4	8	Medium
Lack of employee awareness	3	2	6	Medium

Priority bands: 15–25 = Critical/High, 7–14 = Medium, 1–6 = Low. This gives an SME owner a simple, defensible way to decide where to spend limited security budget first, without needing specialist training to interpret the table.

5. Risk Mitigation Strategies

Risk	Recommended Mitigation
Phishing	Email filtering, employee training, simulated phishing exercises
Ransomware	Regular offline backups, endpoint protection, patch management
Weak/reused passwords	Enforce password policies, enable multi-factor authentication (MFA)
Unpatched software	Scheduled patch cycles, automated update policies
Insider threats	Role-based access control, activity logging, least-privilege access

Risk	Recommended Mitigation
Misconfigured cloud storage	Periodic access audits, default-deny configurations
Lack of employee awareness	Quarterly security awareness sessions, simple reporting channel for suspicious activity

6. Model Validation: Case Study

Scenario (illustrative): *ABC Traders*, a 15-employee retail business with a small office network, shared cloud storage for invoices, and no dedicated IT staff.

Applying the framework:

1. **Identify:** ABC Traders' key assets are its customer database, invoicing system, and point-of-sale terminals.
2. **Assessment:** Using the risk scoring table, phishing (20) and weak passwords (12) rank highest, since staff use personal email habits at work and share one admin login.
3. **Protect:** Recommended first actions — enable MFA on the shared admin account, introduce individual logins, and apply a basic email filter.
4. **Detect/Respond/Recover:** Even without a security team, a simple written incident response checklist (who to call, how to isolate a device, how to restore from backup) closes most of the gap at low cost.

This walk-through demonstrates that the model scales down to very small organizations and produces concrete, affordable next steps rather than abstract recommendations.

7. Findings and Best Practices

- Phishing and weak credential hygiene are consistently the highest-scoring risks for SMEs, and also the cheapest to mitigate — MFA and basic training deliver a disproportionate reduction in risk score for minimal cost.
- A numeric Likelihood × Impact model gives non-technical SME owners a simple way to prioritize spending without needing security expertise to interpret it.
- Even a lightweight, document-based incident response plan meaningfully improves an SME's Respond/Recover posture, since the main gap is usually preparedness rather than tooling.

8. Conclusion

This project presented a practical, low-overhead risk assessment framework for SMEs, built on the NIST Cybersecurity Framework and a simple Likelihood × Impact scoring metric. Applied to a representative case study, the model successfully identified the highest-priority risks and mapped them to affordable mitigation steps, showing that structured risk assessment is achievable even for organizations without a dedicated security team.